



GDRock Full GDPR Compliance Checklist

25-step interactive board · Pro & Agency tiers · 2026

Work through these 25 steps in order. Each has a status column — update it as you complete each action. Review the full checklist at least annually and after any major change to your data processing.

FOUNDATION (Steps 1–5)

#	Action	Notes	Status
1	Appoint a Data Protection Responsible (DPR) or DPO	Designate a named individual responsible for GDPR compliance. DPO mandatory for public authorities and certain large-scale processors.	■
2	Map all personal data flows	Document what data you collect, where it comes from, who processes it, where it goes, and how long you keep it. Use the GDRock Retention Table.	■
3	Identify lawful basis for each processing activity	For every processing activity, document which Art. 6 basis applies. Complete a Legitimate Interests Assessment (LIA) where needed.	■
4	Publish GDPR-compliant privacy policy	Must include: data categories, purposes, lawful bases, retention periods, data subject rights, DPO contact, transfer safeguards. Use GDRock template.	■
5	Install cookie banner with genuine Accept / Reject buttons	Non-essential cookies must not fire before consent. Use GDRock Cookie Banner Script or Care hosted banner.	■

DATA SUBJECT RIGHTS (Steps 6–10)

#	Action	Notes	Status
6	Set up a process for access requests (Art. 15)	Respond within 30 days. Provide free copy of data. Document each request and response.	■
7	Set up a process for erasure requests (Art. 17)	Delete or anonymise data within 30 days unless legal obligation requires retention. Inform sub-processors to delete too.	■
8	Set up a process for rectification requests (Art. 16)	Correct inaccurate data within 30 days. Notify sub-processors.	■
9	Set up a process for portability requests (Art. 20)	Provide data in machine-readable format (CSV/JSON) within 30 days.	■
10	Set up a process for objection requests (Art. 21)	Stop processing within 30 days unless compelling legitimate grounds exist. Always stop for direct marketing.	■

CONSENT & MARKETING (Steps 11–14)

#	Action	Notes	Status
11	Obtain valid marketing consent	Consent must be freely given, specific, informed and unambiguous. Use a double opt-in. Keep dated consent records.	■
12	Provide easy unsubscribe in every marketing email	One-click unsubscribe required. Process within 10 business days.	■
13	Audit existing email list for valid consent	Remove anyone without a documented consent record. Run a re-permission campaign if uncertain.	■
14	Review and update cookie consent preferences	Re-prompt users at least every 12 months or when cookie purposes change.	■

DATA PROCESSORS & TRANSFERS (Steps 15–18)

#	Action	Notes	Status
15	Sign DPAs with all data processors	Required under Art. 28. Cover: Shopify, Stripe, email platform, analytics, advertising, hosting, support tools.	■
16	Maintain a Record of Processing Activities (RoPA)	Required under Art. 30 for most businesses. Document: purpose, categories, recipients, transfers, security measures.	■
17	Assess international data transfers	For transfers outside EEA: ensure SCCs, adequacy decision, or BCRs are in place. Document the transfer mechanism.	■
18	Review sub-processors of your processors	Your processors' sub-processors also process your customers' data. Review their DPAs and security.	■

SECURITY & INCIDENT RESPONSE (Steps 19–22)

#	Action	Notes	Status
19	Implement appropriate technical security measures (Art. 32)	Minimum: HTTPS, strong passwords, 2FA, encrypted backups, access controls, regular security updates.	■
20	Implement organisational security measures	Staff training on data protection, clear desk policy, device encryption, secure disposal of data.	■
21	Create a data breach response plan	Use GDRock Breach Response Pack. 72-hour notification obligation. Test the plan annually.	■
22	Set up breach detection & monitoring	Enable security logging, intrusion detection, login anomaly alerts. Know who to call if a breach occurs.	■

ONGOING COMPLIANCE (Steps 23–25)

#	Action	Notes	Status
23	Train all staff who handle personal data	Annual GDPR refresher training. Document attendance. Include in onboarding for new hires.	■

24	Review and update this checklist annually	GDPR and EU enforcement guidance evolves. Review after any significant change to your business or data processing.	■
25	Conduct a Privacy Impact Assessment (DPIA) for high-risk processing	Required under Art. 35 for processing that is 'likely to result in high risk'. E.g. large-scale profiling, processing special category data.	■

GDRock Pro & Agency tiers include this checklist as an interactive Notion board with status tracking, assignees, and due dates. Upgrade at gdrock.com/pro

© 2026 GDRock GDPR Compliance · gdrock.com · support@gdrock.com | Templates are for informational purposes. Consult a legal professional for your specific situation.